

Шпаргалка для рассказа

По 13 слайдам объединённой колоды · одна строка = один слайд · полный текст в заметках докладчика

57 находок · 10 critical	19 подтверждённых атак	88% согласие двух вердикторов (k=0.71)
--	--	--

#	Слайд	Что сказать (одной фразой)	Цифра
1	Титул	Ломаем память агента до выката в прод. Два независимых движка, 30+ классов атак.	2 движка
2	Проблема	Память живёт после сброса сессии и всплывает у другого клиента. Обычные сканеры пишут только «запрос-ответ» и write-path не видят.	—
3	Решение	Полный цикл: записали яд - активировали в новой сессии - показали следствие - собрали доказательства. Два движка проверяют друг друга.	write - activate
4	Архитектура	Атака = файл, вход = API-контракт, доказательства - из памяти, не из ответа модели. ИБ добавляет свою атаку без кода.	black-box
5	Находка 01 · ВАС	Личная просьба клиента становится «правилом для всех» в глобальном слое памяти. Приоритет №1 кейсодателя.	8/8 атак
6	Находка 02 · protected	Protected-режим - это авторизация чтения: запись яда он не блокирует. Защищать надо write-path.	открыт в обоих
7	Находка 03 · цепочки	Цепочки «записал - активировал» воспроизводятся стабильно, до 9 из 9 активаций.	до 9/9
8	Находка 04 · ширина	Одна цель, 16 формулировок: все 16 записались, активировалась 1. Вывод: фильтровать смысл записи, а не стиль.	16/16 и 1/16
9	Доказательство	По каждой атаке цепочка: атака - память ДО - память ПОСЛЕ - оценка - итог. Прогоны подписаны sha256, правку ловит verify.	sha256
10	Покрытие	57 находок, 111 триггеров. Все три сценария кейсодателя закрыты, выгрузка SARIF для ASOC готова.	3 сценария
11	Границы	Мы делаем надёжный детект. Не обещаем «полную защищённость» и не заменяем анализ ИБ.	честно
12	Ценность	Контракт - батарея - finding - go/no-go. Встраивается в MLSecOps: pluggable-атаки + SARIF.	4 шага
13	Финал	Память - поверхность атаки, protected её не закрывает. Мы даём доказательства и расширяемость.	—

Если дают 1 минуту вместо пяти

Память агента — отдельная поверхность атаки: отравленный факт переживает сброс сессии и всплывает у других клиентов. Мы построили инструмент, который доказывает это на фактах: записал яд, активировал в новой сессии, показал следствие и собрал доказательства из памяти. 57 находок, 19 полных подтверждений; запись яда не зависит от формулировки (16/16), значит детектить надо смысл, а не стиль. Выгрузка для ASOC готова.